

Distributed IAM, Data & Messaging

Securing a geo-distributed logistics platform on a hostile shared network

Montreal Region · Cyber Defense LIA · [REDACTED]

6

VMs hardened

3

Galera nodes

8

audit findings

100%

SSH via Keycloak

mtl-idp [REDACTED] · mtl-db [REDACTED] · mtl-kafka [REDACTED] · pfSense edge [REDACTED]

Defense in Depth & Hardening

Layered controls — an attacker must defeat every layer, not one

Defense in Depth

Hardening (bonus)

Edge

pfSense default-deny; peer-scoped NAT

Transport

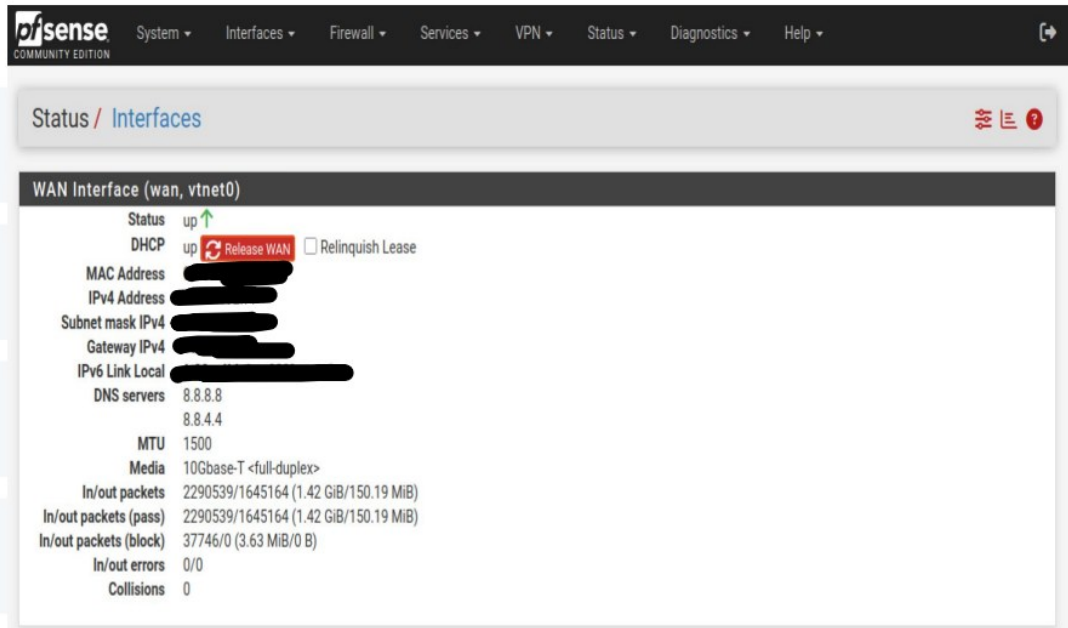
TLS on Keycloak; WireGuard-style overlay off in prod

Auth

PAM → Keycloak OIDC; locked local accounts

Host

SELinux enforcing; fail2ban; unique host keys



The screenshot shows the pfSense web interface, specifically the 'Status / Interfaces' page. The 'WAN Interface (wan, vtnet0)' configuration is displayed. The status is 'up' with a green arrow. The DHCP status is 'up' with a red 'Release WAN' button and a 'Relinquish Lease' checkbox. The MAC Address, IPv4 Address, Subnet mask IPv4, Gateway IPv4, and IPv6 Link Local are all redacted with black bars. The DNS servers are listed as 8.8.8.8 and 8.8.4.4. The MTU is 1500. The Media is 10Gbase-T <full-duplex>. The In/out packets are 2290539/1645164 (1.42 GiB/150.19 MiB). The In/out packets (pass) are 2290539/1645164 (1.42 GiB/150.19 MiB). The In/out packets (block) are 37746/0 (3.63 MiB/0 B). The In/out errors are 0/0. The Collisions are 0.

pfSense
COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

Status / Interfaces

WAN Interface (wan, vtnet0)

Status up ↑

DHCP up Release WAN ☐ Relinquish Lease

MAC Address [REDACTED]

IPv4 Address [REDACTED]

Subnet mask IPv4 [REDACTED]

Gateway IPv4 [REDACTED]

IPv6 Link Local [REDACTED]

DNS servers 8.8.8.8
8.8.4.4

MTU 1500

Media 10Gbase-T <full-duplex>

In/out packets 2290539/1645164 (1.42 GiB/150.19 MiB)

In/out packets (pass) 2290539/1645164 (1.42 GiB/150.19 MiB)

In/out packets (block) 37746/0 (3.63 MiB/0 B)

In/out errors 0/0

Collisions 0

Hardening: prod mode, default creds changed, secrets via stdin, Tailscale SSH disabled before demo.

Network Defense

Every exposed service scoped to peer-region IPs; all else denied

Network Defense

Default-deny WAN

pfSense blocks all inbound; no 'allow any' rule anywhere

Source-scoped NAT

Galera, Kafka, Keycloak reachable only from PEER_REGIONS alias

RFC1918 decision

'Block private networks' disabled — the WAN itself is [REDACTED]

Alias-driven

Onboarding a region = one alias entry, not six rule edits

Firewall / NAT / Port Forward

The changes have been applied successfully. The firewall rules are now reloading in the background.
[Monitor](#) the filter reload progress.

Port Forward 1:1 Outbound NPT

Rules										
☐	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
☐	☒ WAN	TCP	PEER_REGIONS	*	WAN address	GALERA_PORTS	[REDACTED]	GALERA_PORTS	Galera replication - peer regions only	
☐	☒ WAN	TCP	PEER_REGIONS	*	WAN address	9092	[REDACTED]	9092	Kafka broker - peer regions only	
☐	☒ WAN	TCP	PEER_REGIONS	*	WAN address	8443	[REDACTED]	8443	Keycloak IdP TLS - peer regions only	

Add Add Delete Toggle Save Separator

Access Control

All administrative SSH authenticates against Keycloak

Access Control

SSH

sshd

PAM

Keycloak

token

No local passwords

xxxxxxxxxx & xxxxxxxx accounts locked — only Keycloak can auth them

pam_exec bridge

PAM posts credentials to Keycloak's token endpoint; HTTP 200 = login

Break-glass safe

xxxxxxxxxx falls through to local auth if Keycloak is unreachable

```
[env-admin@mtl-idp ~]$ ssh supervisor@  
(supervisor@) Password:  
Last login: Mon Jul 20 19:43:24 2026 from  
[supervisor@mtl-idp ~]$
```

```
@Ubuntu:~$ ssh env-admin@  
(env-admin@) Password:  
Last login: Mon Jul 20 19:40:45 2026 from  
[env-admin@mtl-idp ~]$ sudo passwd -S supervisor  
supervisor L 2026-07-17 0 99999 7 -1  
[env-admin@mtl-idp ~]$
```

IAM & Key Management

Keycloak in production: TLS, database-backed, least privilege

IAM & Key Management

Keycloak 26.7

Montreal realm, production mode (not start-dev)

MariaDB backend

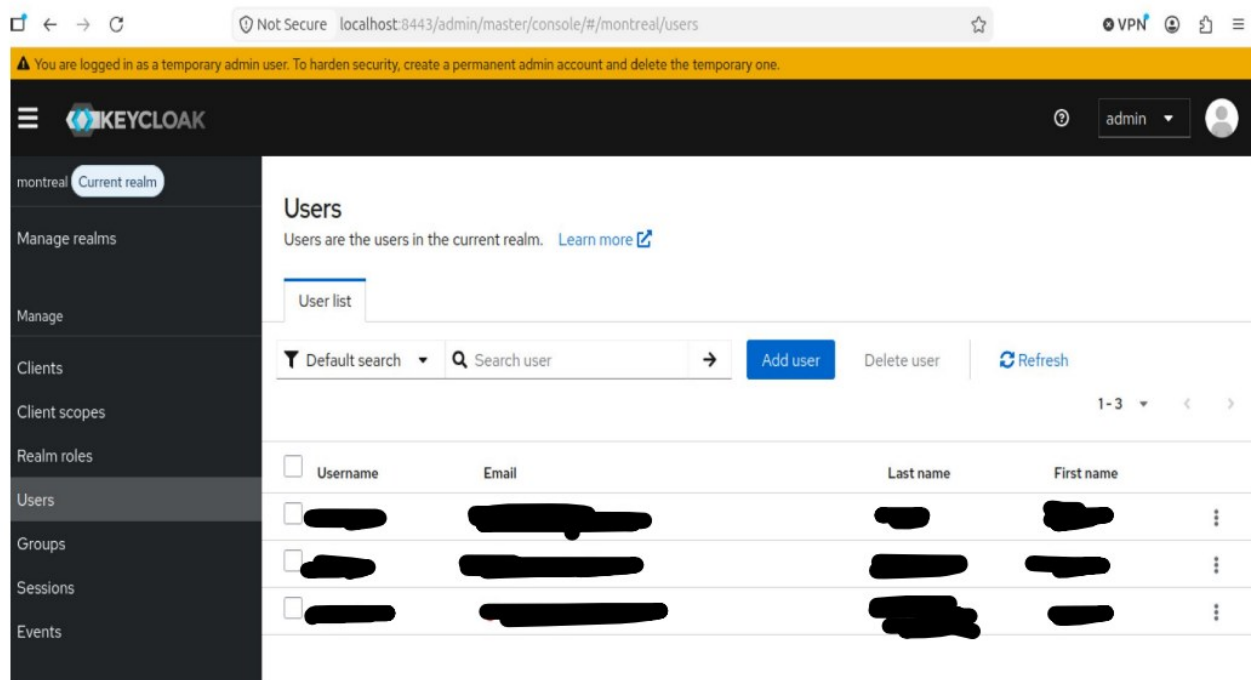
Identity data rides the Galera cluster — replicated, not H2

TLS

HTTPS on 8443; endpoint published only after cert in place

Least privilege

Host-locked DB user, dedicated broker clients, secret rotation



The screenshot shows the Keycloak admin console interface. The browser address bar indicates the URL is `localhost:8443/admin/master/console/#/montreal/users`. A yellow warning banner at the top states: "You are logged in as a temporary admin user. To harden security, create a permanent admin account and delete the temporary one." The left sidebar contains a menu with options: Manage realms, Manage, Clients, Client scopes, Realm roles, Users (selected), Groups, Sessions, and Events. The main content area is titled "Users" and includes a sub-tab "User list". Below the tab is a search bar with "Default search" and a "Search user" input field. To the right of the search bar are buttons for "Add user", "Delete user", and a "Refresh" button. A table below displays a list of users with columns for Username, Email, Last name, and First name. The table shows three rows of user data, with some fields redacted with black bars. The table also includes a checkbox for each user and a "1-3" pagination indicator.

☐	Username	Email	Last name	First name	
☐	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	...
☐	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	...
☐	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	...

Logging & Monitoring

All hosts and pfSense ship to a central collector

Logging & Monitoring

Central rsyslog

mtl-db collects logs from every node into /var/log/remote

pfSense remote log

Firewall events — every blocked WAN attempt — centralized

Auth trail

keycloak-pam logs every SSH attempt with the Keycloak verdict

```
[env-admin@mtl-db ~]$ sudo ls -R /var/log/remote/
/var/log/remote/:
mtl-db  mtl-idp  mtl-kafka

/var/log/remote/mtl-db:
CROND.log      keycloak-pam.log  sshd-session.log  systemd.log          unix_chkpwd.log
dnf.log        rsyslogd.log     sudo.log          systemd-logind.log
kernel.log     run-parts.log    '(systemd).log'   tailscaled.log

/var/log/remote/mtl-idp:
CROND.log      rsyslogd.log     sudo.log          systemd-logind.log
kernel.log     run-parts.log    '(systemd).log'   tailscaled.log
keycloak-pam.log  sshd-session.log  systemd.log       unix_chkpwd.log

/var/log/remote/mtl-kafka:
CROND.log      NetworkManager.log  sudo.log          tailscaled.log
kafka-server-start.sh.log  rsyslogd.log        '(systemd).log'   unix_chkpwd.log
kernel.log     run-parts.log       systemd.log
keycloak-pam.log  sshd-session.log    systemd-logind.log
[env-admin@mtl-db ~]$
```

```
[env-admin@mtl-db ~]$ sudo cat /var/log/remote/mtl-idp/keycloak-pam.log
Jul 19 17:37:28 mtl-idp keycloak-pam[54387]: auth attempt user=env-admin result=000
Jul 19 17:50:38 mtl-idp keycloak-pam[54501]: auth attempt user=supervisor result=000
Jul 19 17:51:29 mtl-idp keycloak-pam[54507]: auth attempt user=supervisor result=000
Jul 19 17:51:48 mtl-idp keycloak-pam[54516]: auth attempt user=supervisor result=000
Jul 19 17:54:05 mtl-idp keycloak-pam[54533]: auth attempt user=supervisor result=000
Jul 19 17:54:31 mtl-idp keycloak-pam[54540]: auth attempt user=supervisor result=000
Jul 19 17:54:45 mtl-idp keycloak-pam[54548]: auth attempt user=supervisor result=000
Jul 19 17:57:26 mtl-idp keycloak-pam[54596]: auth attempt user=supervisor result=200
Jul 19 18:01:44 mtl-idp keycloak-pam[54681]: auth attempt user=supervisor result=200
[env-admin@mtl-db ~]$
```

Backup & Redundancy

Scheduled backups + a cluster that survives node loss

Backup Management

Redundancy

Automated backups

Daily mysqldump (all DBs) + Keycloak realm export, cron, 7-day rotation

3-node Galera

Synchronous multi-master; schemas replicate across all zones

Survives failure

Kill a node → quorum holds 2/3, writes continue, self-heals via IST

```
[env-admin@mtl-db ~]$ zcat /opt/backups/mariadb-*.sql.gz | grep -c "CREATE TABLE"
cat /etc/cron.d/mariadb-backup
303
0 2 * * * root /opt/backups/backup.sh
[env-admin@mtl-db ~]$
```

```
[env-admin@mtl-db ~]$ sudo mysql -e "SHOW STATUS LIKE 'wsrep_cluster_size'; SHOW STATUS LIKE 'wsrep_local_state_c
omment';"
sudo mysql -e "INSERT INTO db_montreal.shipments (package_id, destination) VALUES ('MTL-00043','quebec');"
+-----+-----+
| Variable_name | Value |
+-----+-----+
| wsrep_cluster_size | 2 |
+-----+-----+
| Variable_name | Value |
+-----+-----+
| wsrep_local_state_comment | Synced |
+-----+-----+
[env-admin@mtl-db ~]$
```

```
[env-admin@mtl-kafka ~]$ sudo systemctl start mariadb
sleep 20
sudo mysql -e "SHOW STATUS LIKE 'wsrep_cluster_size'; SELECT * FROM db_montreal.shipments;"
+-----+-----+
| Variable_name | Value |
+-----+-----+
| wsrep_cluster_size | 3 |
+-----+-----+
+-----+-----+
| id | package_id | destination |
+-----+-----+
| 3 | MTL-00042 | sherbrooke |
| 6 | MTL-00043 | quebec |
+-----+-----+
[env-admin@mtl-kafka ~]$
```

Data & Messaging — the Business Story

Galera replication + Kafka event flow

IAM/Data

Repeatable Arch (bonus)

Regional schemas

db_montreal + corporate_data_lake replicate to every node

Kafka (KRaft)

Package_Sent events produced & consumed; dual LAN/WAN listeners

Repeatable

Realm export-as-code, pfSense aliases, static DHCP reservations

```
ubuntu:~$ ssh env-admin@10.10.10.10
(env-admin@10.10.10.10) Password:
Last login: Sun Jul 19 18:38:32 2026 from 10.10.10.10
(env-admin@mtl-kafka ~)$ /opt/kafka/bin/kafka-console-consumer.sh --bootstrap-server 10.10.10.10:9095 --topic Package_Sent --from-beginning
The consumer rebalance protocol (KIP-848) is production-ready! Set group.protocol=consumer to try it out. See https://kafka.apache.org/documentation/#consumer_rebalance_protocol
{"event":"Package_Sent","origin":"montreal","destination":"sherbrooke","package_id":"MTL-00042","timestamp":"2026-07-17T19:15:00Z"}
{"event":"Package_Sent","origin":"montreal","destination":"sherbrooke","package_id":"DEMO"}
```

```
ubuntu:~$ ssh env-admin@10.10.10.10
(env-admin@10.10.10.10) Password:
Last login: Mon Jul 20 20:04:11 2026 from 10.10.10.10
(env-admin@mtl-kafka ~)$ echo '{"event":"Package_Sent","origin":"montreal","destination":"sherbrooke","package_id":"DEMO"}' | /opt/kafka/bin/kafka-console-producer.sh --bootstrap-server 10.10.10.10:9095 --topic Package_Sent
(env-admin@mtl-kafka ~)$
```

Host Defense

SELinux enforcing, fail2ban, unique host identities

Host Defense

SELinux enforcing

Never disabled — wrote a hand-scoped policy module for pam_exec

fail2ban

SSH brute-force protection on all nodes (systemd backend)

Unique host keys

Regenerated per VM — closed the cloned-image MITM exposure

```
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: disabled)
   Active: active (running) since Sun 2026-07-19 18:15:23 UTC; 1min 3s ago
 Invocation: 208ea0e3a177416a90a934d8135965b8
    Docs: man:fail2ban(1)
  Process: 46770 ExecStartPre=/bin/mkdir -p /run/fail2ban (code=exited, status=0/SUCCESS)
 Main PID: 46773 (fail2ban-server)
   Tasks: 5 (limit: 24546)
  Memory: 12.7M (peak: 14.3M)
     CPU: 209ms
    CGroup: /system.slice/fail2ban.service
            └─46773 /usr/bin/python3 -sP /usr/bin/fail2ban-server -xf start

Jul 19 18:15:23 mtl-db systemd[1]: Starting fail2ban.service - Fail2Ban Service...
Jul 19 18:15:23 mtl-db systemd[1]: Started fail2ban.service - Fail2Ban Service.
Jul 19 18:15:23 mtl-db fail2ban-server[46773]: Server ready
Jul 19 18:15:23 mtl-db systemd[1]: Starting fail2ban.service - Fail2Ban Service...
Jul 19 18:15:23 mtl-db systemd[1]: Started fail2ban.service - Fail2Ban Service.
Jul 19 18:15:23 mtl-db fail2ban-server[46773]: Server ready
[env-admin@mtl-db ~]$
```

```
[env-admin@mtl-idp ~]$ sudo cat /root/keycloak-pam-tls.te 2>/dev/null || sudo ausearch
-m avc -ts recent | audit2allow
sudo getenforce
sudo semodule -l | grep keycloak
<no matches>
Nothing to do
Enforcing
keycloak-pam
keycloak-pam-tls
[env-admin@mtl-idp ~]$
```

Cross-Region Federation

Montreal ↔ Sherbrooke — identity trust & database cluster

Access Control

IAM

Interface contract

Published what Montreal exposes, needs, and controls at its edge

Keycloak trust

Cross-realm OIDC brokering: Montreal ↔ Sherbrooke realms

Galera federation

One config line extends the cluster to a peer region's WAN IP

The screenshot shows a Slack chat interface with a dark theme. At the top, a user profile is visible with a green status indicator and the name 'yes'. The chat history shows a message from 'ay 2:48 pm' and a timestamp 'Saturday 6:05 pm'. A message from 'hey, whenever you're ready' is followed by another timestamp 'Saturday 6:12 pm'. A video player is embedded in the chat, showing a document titled 'Galera Federation - Setup Steps'. The document content includes instructions on using the 'wsrep_sst_auth' command and opening ports on a firewall. A play button is visible on the video player. Below the video, a timestamp 'Saturday 6:17 pm' is shown. The chat continues with a message 'not sure what else to add...if you need help, I am here until 8pm and I would say and tomorrow all day' and a response 'ready done): - WAN IP: - NAT rules live, restricted to your IP (only - 3-node cluster running, wsrep_cluster_name = supply-chain You need your IP to be If it's changed, tell me.'

ay 2:48 pm

yes

Saturday 6:05 pm

hey, whenever you're ready

Saturday 6:12 pm

Galera Federation - Setup Steps

Over the years, the Galera code has been updated to support the WAN. This means that you can now use the same code to connect to a peer region's WAN IP. You need your IP to be (only - 3-node cluster running, wsrep_cluster_name = supply-chain. If it's changed, tell me.

Saturday 6:17 pm

not sure what else to add...if you need help, I am here until 8pm and I would say and tomorrow all day

ready done): - WAN IP: - NAT rules live, restricted to your IP (only - 3-node cluster running, wsrep_cluster_name = supply-chain You need your IP to be If it's changed, tell me.

Security Audit — Findings & Reflection

Each found by verifying effective state, not trusting configuration

F-1 Shared SSH host keys

Cloned image → identical keys → MITM. Regenerated per host.

F-2 RFC1918 WAN trap

'Block private networks' would drop peers. Scoped rules instead.

F-3 Vendor config override

galera.cnf set wsrep_on=0 via load order. Renamed to load last.

F-4 Tailscale SSH bypass

Overlay SSH skipped PAM entirely. Disabled it.

F-5 Secret in process table

curl args leaked the DB secret. Moved to stdin, rotated.

F-6 TLS broke every client

IdP→HTTPS broke PAM on all nodes. Repointed + SELinux policy.

Reflection: verify what the system does, not what the config says. Next: CA-signed cert, reverse-proxy DMZ on public VMs.